

Cryptographic Protocol Analysis and Verification

UT Dallas Team 1

Nathaniel Simmons nis190000@utdallas.edu

Zarish Mehboob zxm200007@utdallas.edu

David Leung dal190004@utdallas.edu

Arturo Yundt-Pacheco aay200001@utdallas.edu

Sponsor: NSA, Ed Ziegler

Agenda

- Purpose Statement
- Motivation
- Characterization of Methods Used
- Procedures/Plans
- Schedule
- Deliverables
- Limitations and Delimitations
- Detailed Findings
- Issues/Challenges
- Conclusions and Recommendations
- Investigator Biographies
- Acronyms
- Terms/Definitions

Purpose Statement

- Analyze/verify the correctness of the cryptographic protocol: BACnet/SC
 - We will use the CPSA tool from MITRE to accomplish this task
- Each security property the protocol intends to provide will be analyzed
- Findings will be documented in a report
- If flaws found:
 - Findings can potentially be published
 - Remediations can be researched/proposed
 - If potential remediations are found, they can also be formally verified

Motivation

- Cryptography is the keystone to the security of all computer networks
- Cryptographic protocols may not have the security properties they intend to provide
- Correctness of these protocols should be formally verified

Characterization of Methods Used

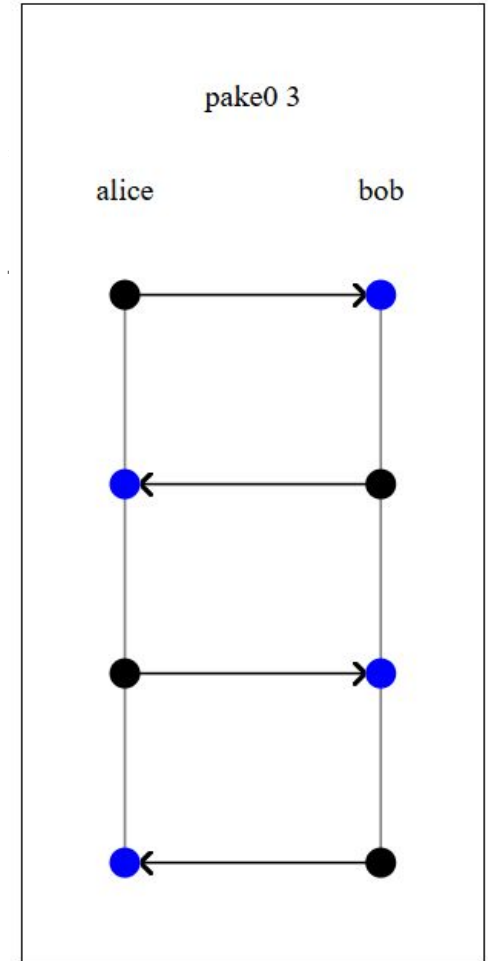
- Cryptographic Protocol Shapes Analyzer (CPSA)
 - The formal verification tool used for analysis/verification
 - Developed by Mitre
 - Input the protocol and security goals
 - Explores every possible execution
 - Analysis of the output can reveal if the security goals are achieved

Procedures / Plans

- CPSA Training
- Research BACnet protocol
- Model/verify the protocol using CPSA
- Document Findings



source: [zenatix](#)



Schedule

9/2 - 9/8	Submit Proposal
9/9 - 10/17	CPSA Training
10/21 - 10/25	Prepare Midterm report and presentation
10/28 - 11/1	Literary Review of BACNet Paper
11/4 - 11/22	Implement BACNet/SC in CPSA
12/2 - 12/6	Prepare Final report and presentation

Deliverables

- Midterm report/presentation - 10/25
 - A report that shares an update on progress and challenges
- Final report/presentation - 12/6
 - A report detailing the protocol and findings from the verification
- CPSA code - 12/6
 - Included in the appendix of our final report

Progress to date

- CPSA training completed
- Reviewed the BACnet/SC paper
- BACnet/SC modeled in CPSA
- BACnet/SC formally analyzed and verified

Limitations and Delimitations

- We focus on core functionality of cryptographic communication
 - TLS macro provided
- Narrowed scope for modeling utilizes resources effectively (i.e. time, computational power)
- CPSA is well suited for analyzing logic of network communications rather than implementation of specific nuances
- Real-world network issues not accounted for
- Behavior of devices or systems due to human configuration errors not included

Summary of Results

- We learned how to utilize the CPSA tool
- We reviewed the BACNet/SC literature
- We implemented BACNet/SC in CPSA
- We verified the multiple-client single-server network architecture

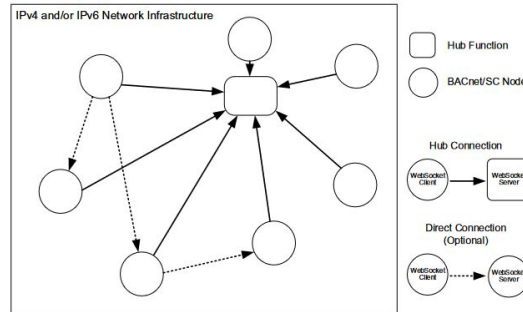
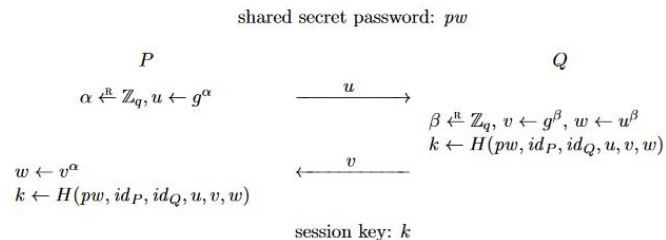
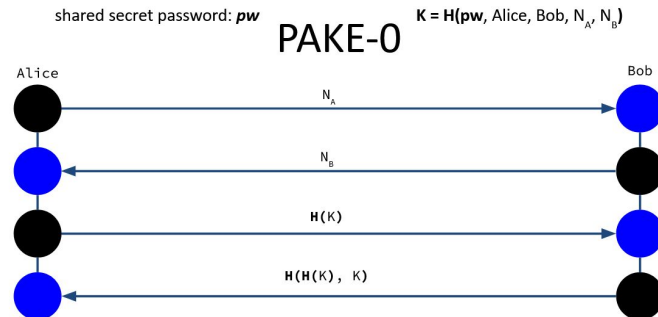
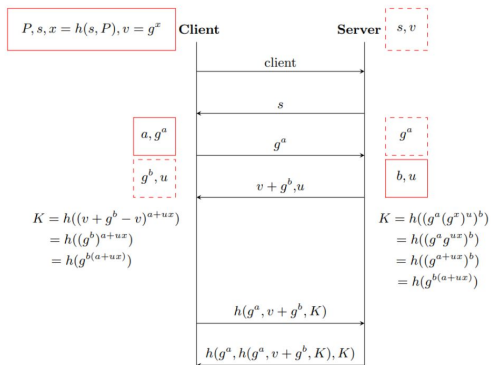


Figure AB-1. BACnet/SC Logical Network Topology

CPSA Training

- Modeled and verified protocols
 - Pake0
 - Pake1
 - SRP3
- Modelled BACnet/SC

```
(defprotocol srp basic
  (defrole client
    ;; pwd salt x(hash) na nb
    (vars (c name) (a b u x rndx) (salt data) (gx locn))
    (trace
      (load gx "init")
      (stor gx (exp (gen) x))
      (send c)
      (recv salt)
      (send (exp (gen) a))
      (recv (cat (enc (exp (gen) b) (exp (gen) x)) u))
      ;; K = (hash (hash (exp (gen) (mul a b)) (exp (gen) (mul l
      ;; h( g^(ab) + g^(bux)) = h( g^(ab + bux))
      (send (hash (exp (gen) a) (enc (exp (gen) b) (exp (gen) x)
      ;; h( g^a above K)
      (recv (cat (hash (exp (gen) a) ;; g^a
      (hash (exp (gen) a) (enc (exp (gen) b) (exp (gen) x)) (has
      (hash (hash (exp (gen) (mul a b)) (exp (gen) (mul b u x)))
    )
    (uniq-gen a x)
```



BACnet Overview

- Building Automation & Control Networks
 - e.g. HVAC, fire, security, lighting, etc.
- Objects
 - contain properties with information related to itself
- Services
 - requests sent from one BACnet device to another to perform an action

Object_Name	SPACE TEMP
Object_Type	ANALOG INPUT
Present_Value	72.3
Status_Flags	Normal, InService
High_Limit	78.0
Low_Limit	68.0

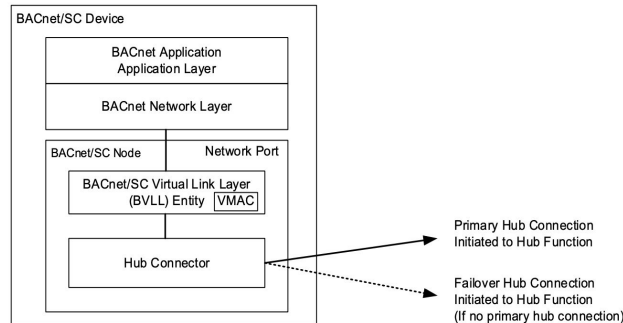
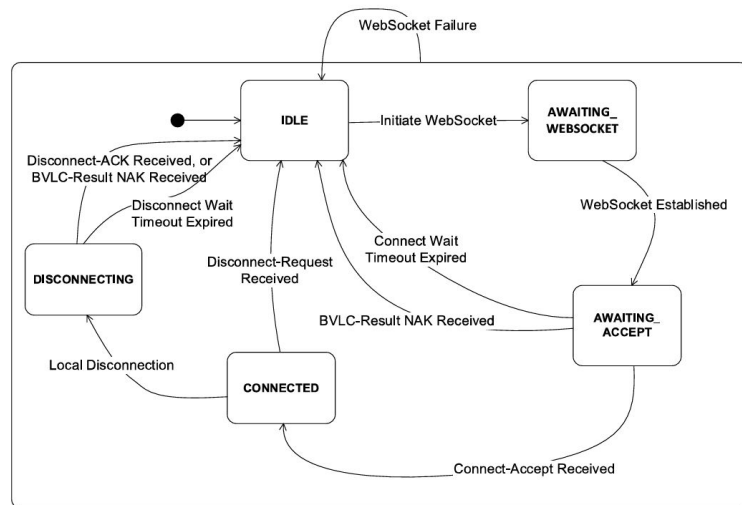


Figure AB-2. Example BACnet/SC Device

BACnet Secure Connect

- Addendum to base BACnet Protocol
 - Encrypted connection between devices
- Security Applied in Transport Layer
- Uses TLS secure WebSockets
 - peer authentication, message integrity, encryption



BACnet Layers

BACnet Application Layer							
BACnet Network Layer							
ISO 8802-2 (IEEE 802.3) Type 1		MS/TP	PTP	LonTalk	BVLL (Annex J)	BVLL (Annex U)	BZLL
ISO 8802-3 (IEEE 802.3)	ARCNET	EIA-485	EIA-232		IPv4	IPv6	Zigbee
							Secure Connect BVLL (Annex YY)
							WebSocket

Equivalent OSI Layers

Application
Network
Data Link
Physical

Detailed Findings

```
(defrole client ;; Role in which the client connects to a server
  (vars
    (c s ca name) ;; c - client u - username, s - server,
                    ;; ca - certificate authority
    (cr sr random32) ;; cr - client random, sr - server random for TLS
    (x rndx) ;; client's Diffie-Hellman secret
    (y expt) ;; server's Diffie-Hellman secret
    (spk cpk akey) ;; server's and client's public key's
  )
  (trace
    (mTLS send recv cr sr x y s spk (invk spk) c cpk (invk cpk) ca
      (HandshakeSecret (DHpublic y) x)) ;; establish TLS session with server
    ;;add some message
  )
  (uniq-gen x)
)

(defrole server ;; Role in which the server accepts a client connection
  (vars
    (c s ca name) ;; c - client u - username, s - server,
                    ;; ca - certificate authority
    (cr sr random32) ;; cr - client random, sr - server random for TLS
    (y rndx) ;; client's Diffie-Hellman secret
    (x expt) ;; server's Diffie-Hellman secret
    (spk cpk akey) ;; server's and client's public key's
  )
  (trace
    (mTLS recv send cr sr x y s spk (invk spk) c cpk (invk cpk) ca
      (HandshakeSecret (DHpublic x) y)) ;; establish TLS session with client
  )
  (uniq-gen y)
)
```

Detailed Findings

```
;;client perspective
(defskeleton bacnet ;;
  (vars (clienta clientb hub ca name) (cra crb sr random32) (y expt) (x rndx) (spk cpka cpkb akey))
  (defstrandmax client (c clienta) (s hub) (ca ca) (cr cra) (spk spk) (cpk cpka))
  (defstrandmax client (c clientb) (s hub) (ca ca) (cr crb) (spk spk) (cpk cpkb))

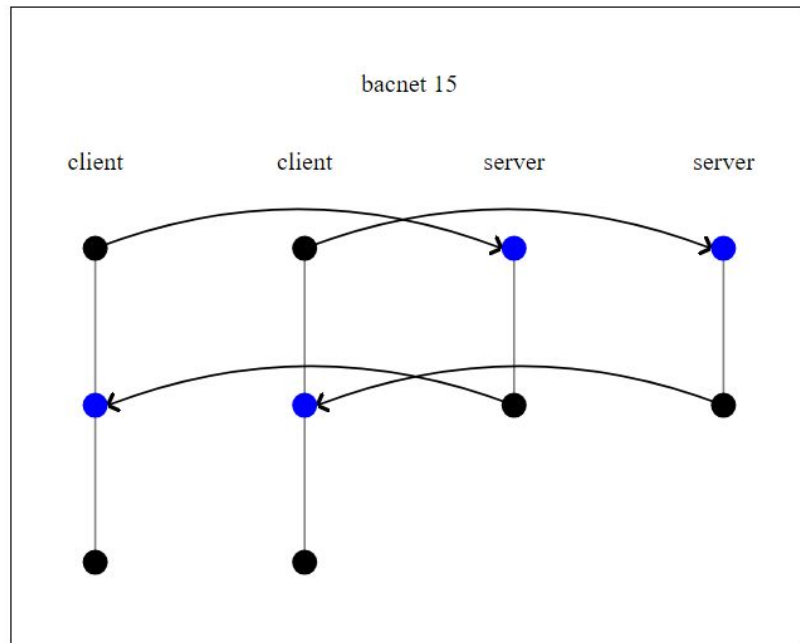
  (uniq-gen cra crb)
  (non-orig (invk cpka) (invk cpkb) (privk ca) (invk spk) )
)

;; server perspective
(defskeleton bacnet
  (vars (clienta clientb hub ca name) (cra crb sr random32) (y rndx) (x expt) (spk cpka cpkb akey))
  (defstrandmax server (c clienta) (s hub) (ca ca) (sr sr) (spk spk) (cpk cpka))
  (defstrandmax server (c clientb) (s hub) (ca ca) (sr sr) (spk spk) (cpk cpkb))

  (uniq-gen sr)
  (non-orig (invk cpka) (invk cpkb) (invk spk) (privk ca))
)
```

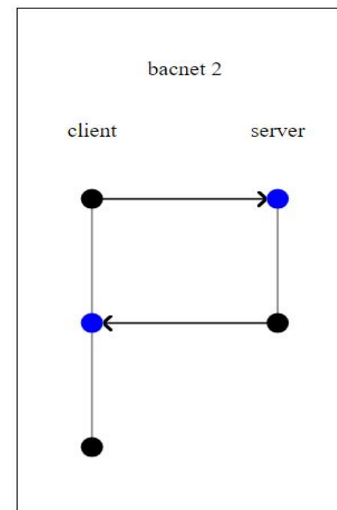
Detailed Findings

Item [15](#), Parent: [0](#).



BACnet/SC: 2 Devices - 1 Server

Item [2](#), Parent: [0](#).

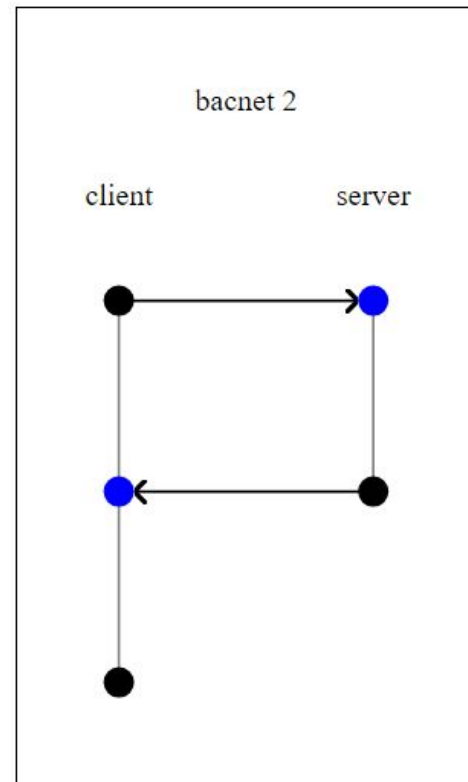


BACnet/SC: 1 Device - 1 Server

Issues and Challenges

- Lack of experience with formal verification
 - Training has proven effective
- Protocol Modeling
 - The specification is complex
 - Numerous addendums
 - Some vague parts in specification
- CPSA Limitations
- Removing certain attributes e.g. Certificate Authority

Item 2, Parent: 0.



Conclusions / Recommendations

- TLS provides a provable strong layer of security
 - Ensure continued use of modern TLS protocols and strong cryptographic configurations
- Explore if changing attributes matches our predictions
 - e.g. removal of certificates did not impact proof
 - Investigate CPSA's abstraction of certificates
- Recommend real-world testing in diverse environments to verify testing
 - Conduct testing in diverse environments to verify resilience under practical conditions

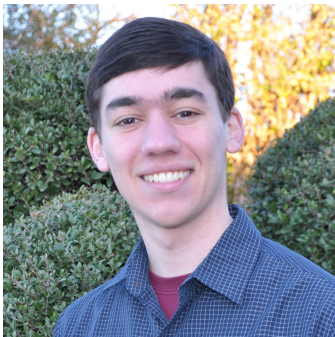
Investigator Biographies

Nate Simmons

UTD MS in CS Student

Cybersecurity research intern at
Lawrence Livermore National Lab

Research intern at UTD Software,
Systems, and Security lab



Arturo Yundt-Pacheco

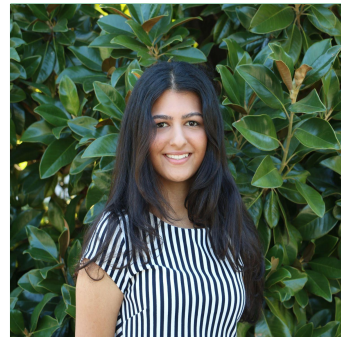
UTD BS in CS Student



Zarish Mehboob

UTD MS in CS Student

Cybersecurity research intern at
Idaho National Lab



David Leung

UTD MS in CS Student



Bibliography

BACnet A Data Communication Protocol for Building Automation and Control Networks. (2020). ASHRAE, 135–2020.

<https://webstore.ansi.org/standards/ashrae/ansiashrae1352020>

Acronyms

ANSI - American National Standards Institute

ASHRAE - The American Society of Heating, Refrigerating and Air-Conditioning Engineers

BACnet - Building Automation and Control Network

BACnet/SC - Building Automation and Control Network Secure Connect

CPSA - Cryptographic Protocol Shapes Analyzer

HVAC&R - Heating, Ventilation, Air Conditioning and Refrigeration

TLS - Transport Layer Security

Terms

ANSI - A standards institute facilitates the development of consensus standards in the US.

ASHRAE - A professional organization focused on HVAC&R and develop standards related to the field. The paper on BACNET was published in their journal in joint with ANSI.

BACnet - An open, standardized protocol used for communication between building automation and control systems.

BACnet/SC - A security protocol built on top of the BACnet communication protocol.

CPSA - A tool developed by MITRE used to analyze and evaluate the security properties of cryptographic protocols.

HVAC&R - A broad field encompassing the design, installation, operation, and maintenance of systems that control the temperature, humidity, and air quality in buildings.

TLS - A cryptographic protocol that provides security for communication over a computer network.

Q+A